- Cedar policies decide the inner logic of what the caller is allowed to see or do.

Together, OAuth and Cedar provide ACME with a layered defense. OAuth verifies who the caller is and which parts of the API they can access, while Cedar decides whether that caller can perform specific actions on specific resources. This separation makes the system both flexible and secure: tokens can be widely recognized across many clients and APIs, while Cedar policies enforce detailed business rules that adapt to ACME’s needs. Next, we’ll look at how OAuth scopes define the broad contours of access, before turning to the ways clients obtain tokens in practice.